

CYBERSECURITY PORTFOLIO

HANDS-ON LAB · NETWORK SECURITY

Firewall Policy & Threat Monitoring

Carter Yanosick

Portfolio Edition

SANITIZED COPY

Original technical content and evidence preserved.
Other participant names removed for public portfolio use.

Week 5 Day 1-3 Lab

Firewall Configuration

Carter Yanosick

Cybersecurity for Professionals

Day 1: Building a Least Privilege Firewall Policy

Part 1: Confirm Basic Zones Exist

Security Zones						+ Add
Name	Type	Interfaces	Zone Protection	User-ID		
trust	Layer3	ethernet1/2, ethernet1/4	zone-protection-trust	✓		
untrust	Layer3	ethernet1/1	zone-protection-untrust			
dmz	Layer3	ethernet1/3	zone-protection-dmz			

Ethernet Interfaces						
Interface	Interface Type	Security Zone	IP Address	Virtual Router	Link State	Comment
ethernet1/1	Layer3	untrust	203.0.113.1/24	default	up	Outside interface
ethernet1/2	Layer3	trust	192.168.1.1/24	default	up	Inside interface
ethernet1/3	Layer3	dmz	10.0.1.1/24	default	up	DMZ interface
ethernet1/4	Layer3	trust	192.168.2.1/24	default	up	Secondary LAN
ethernet1/5	Layer3	None	N/A		down	
ethernet1/6	Layer3	None	N/A		down	
ethernet1/7	Layer3	None	N/A		down	
ethernet1/8	Layer3	None	N/A		down	

Part 2: Recreate the Legacy Rule

13	legacy-allow-all	trust	any	any	untrust	any	any	any	allow	—
----	------------------	-------	-----	-----	---------	-----	-----	-----	-------	---

14	allow-dns	trust	any	any	untrust	any	dns	application-default	allow	—
----	-----------	-------	-----	-----	---------	-----	-----	---------------------	-------	---

15	allow-ntp	trust	any	any	untrust	any	ntp	application-default	allow	—
----	-----------	-------	-----	-----	---------	-----	-----	---------------------	-------	---

16	allow-web-https	trust	any	any	untrust	any	web-browsing-ssl	application-default	allow	—
----	-----------------	-------	-----	-----	---------	-----	------------------	---------------------	-------	---

17	allow-banking-app	trust	any	any	untrust	any	any	service-tcp-8443	allow	—
----	-------------------	-------	-----	-----	---------	-----	-----	------------------	-------	---

18	allow-patching	trust	any	any	untrust	any	ssl	application-default	allow	—
----	----------------	-------	-----	-----	---------	-----	-----	---------------------	-------	---

Part 3: Remove the Legacy Rule and Confirm Default Deny

13	legacy-allow-all	trust	any	any	untrust	any	any	any	allow	—	0	   
12	legacy-allow-all	trust	any	any	untrust	any	any	any	allow	—	0	   
13	allow-dns	trust	any	any	untrust	any	dns	application-default	allow	—	0	   
14	allow-ntp	trust	any	any	untrust	any	ntp	application-default	allow	—	0	   
15	allow-web-https	trust	any	any	untrust	any	web-browsing-ssl	application-default	allow	—	0	   
16	allow-banking-app	trust	any	any	untrust	any	any	service-tcp-8443	allow	—	0	   
17	allow-patching	trust	any	any	untrust	any	ssl	application-default	allow	—	0	   
18	Default Deny	any	any	any	any	any	any	any	deny	—	34,521	   

Part 4: Enable Application Layer Awareness

trustanyanyuntrustanyanydnsapplication-de

Security Policy Rule — allow-web-https

GeneralSourceDestinationApplicationService/URL CategoryActionsTarget

Applicationweb-browsing-ssl

OKCancel

trustanyanyuntrustanyany

Security Policy Rule — allow-banking-app

GeneralSourceDestinationApplication

Applicationany

The banking application rule is currently port-based because the simulator does not provide a custom App-ID signature. This means another application using the same allowed port could potentially match the rule.

Part 4:

Step 1:

Vulnerability Profile — Vuln-Protect-Default

GeneralRules

Severity-based Actions

Critical	reset-both
High	reset-both
Medium	reset-client
Low	default
Informational	default

Cancel

Step 2:

Security Policy Rule — allow-dns

General

Source

Destination

Application

Service

Action

Allow

Profile Setting

Group

Security Profile Group

Vuln-Protect-Default

Log at Session Start

☐ Enable

Log at Session End

☒ Enable

Log Forwarding

default

Schedule

None

QoS Marking

None

Disable Server Response Inspection

☐ Disable

An External Dynamic List (EDL) allows a firewall to automatically use an externally maintained list of known-malicious IP addresses, domains, or other indicators to identify and block threats. If the feed silently stops updating, the firewall may continue relying on outdated threat intelligence, creating a security gap because newly identified malicious indicators will not be blocked.

Part 5: Test the Firewall Policy

Security Policy Rules

+ Add

#	Name	Source Zone	Source Addr	User	Dest Zone	Dest Addr	Application	Service	Action	Profile	Opt	Hits	
1	Allow DNS	trust	any	any	untrust	any	dns	application-default	allow	○	📄	15,420	🔍 ⬆ ⬇ ⛔
2	Allow Web Browsing	trust	any	any	untrust	any	web-browsing, ssl	application-default	allow	○	📄	89,234	🔍 ⬆ ⬇ ⛔
3	Allow Email	trust	any	any	untrust	any	smtp, imap, pop3	application-default	allow	○	📄	5,621	🔍 ⬆ ⬇ ⛔
4	DMZ Web Servers	untrust	any	any	dmz	WebServer-1, WebServer-2	web-browsing, ssl	service-http, service-https	allow	○	📄	45,678	🔍 ⬆ ⬇ ⛔
5	Trust to DMZ	trust	any	any	dmz	any	any	any	allow	○		12,340	🔍 ⬆ ⬇ ⛔
6	Allow ICMP	trust	any	any	untrust	any	ping	application-default	allow	—		3,456	🔍 ⬆ ⬇ ⛔
7	VPN Access	untrust	VPN-Pool	any	trust	any	any	any	allow	○	📄	7,890	🔍 ⬆ ⬇ ⛔
8	Block Social Media	trust	any	any	untrust	any	facebook-base, twitter-base, instagram	application-default	deny	—		2,341	🔍 ⬆ ⬇ ⛔
9	Allow FTP to DMZ	trust	Admin-Subnet	any	dmz	any	ftp	application-default	allow	○		123	🔍 ⬆ ⬇ ✓ ⛔
10	SSH Management	trust	Admin-Subnet	any	trust	Firewall-Mgmt	ssh	service-ssh	allow	—		890	🔍 ⬆ ⬇ ⛔
11	Block Torrents	any	any	any	any	any	bittorrent	any	deny	—		567	🔍 ⬆ ⬇ ⛔
12	legacy-allow-all	trust	any	any	untrust	any	any	any	allow	—		0	🔍 ⬆ ⬇ ✓ ⛔
13	allow-dns	trust	any	any	untrust	any	dns	application-default	allow	○		0	🔍 ⬆ ⬇ ⛔
14	allow-ntp	trust	any	any	untrust	any	ntp	application-default	allow	○		0	🔍 ⬆ ⬇ ⛔
15	allow-web-https	trust	any	any	untrust	any	web-browsing-ssl	application-default	allow	○		0	🔍 ⬆ ⬇ ⛔
16	allow-banking-app	trust	any	any	untrust	any	any	service-tcp-8443	allow	○		0	🔍 ⬆ ⬇ ⛔
17	allow-patching	trust	any	any	untrust	any	ssl	application-default	allow	○		0	🔍 ⬆ ⬇ ⛔
18	Default Deny	any	any	any	any	any	any	any	deny	—	📄	34,521	🔍 ⬆ ⬇ ⛔

Test #1 and #3 never reach the rules you created because they already match the traffic, they are evaluated first and win.

Reflection Questions

1. Rules like legacy-allow-all are often created temporarily to get something working quickly during troubleshooting, migrations, or deployments. Once everything works, administrators may be hesitant to remove the rule because they don't know what systems have become dependent on it. Over time, ownership can also change and the original reason for the rule gets lost. Without regular firewall audits and good documentation, the temporary rule can remain in production for years.
2. A traditional firewall rule mainly determines whether traffic is allowed based on things like IP addresses, protocols, and ports. App-ID goes further by identifying the actual application generating the traffic, rather than assuming that traffic on a particular port belongs to the expected application. For example, allowing TCP 443 alone could potentially allow an unauthorized application operating over that port. App-ID can distinguish that traffic from the legitimate web applications the rule was intended to allow.
3. Specific allow rules define the traffic the organization actually needs, such as DNS, NTP, HTTPS, and the banking application. Default-deny handles everything that doesn't match one of those approved rules. Without the allow rules, legitimate business traffic wouldn't work; without default-deny, unexpected traffic could potentially pass through the firewall. Together they implement least privilege by explicitly permitting necessary traffic and blocking everything else.

Day 2: Traffic Monitoring and Threat Detection

Part 1: Confirm Logging is enabled.

Profile Setting	None
Log at Session Start	☒ Enable
Log at Session End	☒ Enable
Log Enforcement	default

Part 2: Confirm Threat Prevention

Security Policy Rule — allow-web-https

General	Source	Destination	Application
Action	Allow		
Profile Setting	Group		
Security Profile Group	Vuln-Protect-Default		
Log at Session Start	☒ Enable		
Log at Session End	☒ Enable		
Log Forwarding	default		

Part 3:

This section was skipped due to limitations with the available attack simulator.

Part 4:

1. The port scan activity came from 10.50.2.41. There were four TCP-SYN-Scan entries within about 40 seconds, and each one was reaching out to a different external IP address. Since the same device was hitting multiple systems that quickly, it looks like it was scanning the network and looking for possible targets.
2. The most severe activity was the Generic SQL Injection attack coming from 198.51.100.203. It was rated critical and tried to attack 10.50.3.10 multiple times throughout the day. The Web Attack signature is what triggered the firewall to identify and block it.
3. The firewall blocked the SQL injection attempt, which was the right action because it was rated as a critical threat. Something that severe shouldn't just create an alert and still be allowed through. Blocking it stops the attack from reaching the internal server while still giving the security team a record of what happened.
4. I would look into the suspicious user-agent traffic even though it was only rated as low severity. Since it happened multiple times from the same device, I wouldn't automatically assume the traffic was safe just because the firewall allowed it. I would want to check the device and see what was actually generating those requests.

Part 5:

Daily Traffic/Threat Summary

There were 6 blocked events throughout the day. The biggest threat category was Web Attack with 3 blocked SQL injection attempts. Malware, a DNS DGA-domain lookup, and an SMB EternalBlue signature each had one blocked event.

The top source IP was 10.50.2.41 with 4 events, all related to the port scanning activity. 10.50.1.19 and 198.51.100.203 were tied for second with 3 events each. I would investigate 10.50.2.41 because of the repeated scanning and 198.51.100.203 because it made multiple critical SQL injection attempts.

I would escalate the repeated Generic SQL Injection attacks from 198.51.100.203 to Tier 2. They were rated critical and targeted the same internal server multiple times, so I would want a deeper investigation even though the firewall blocked them.

Day 3:

Part 1: Create the Security Zones

branch-users	Layer3
branch-servers	Layer3
guest-wifi	Layer3

Step 2: Map Interfaces to the New Zones

Interface mapping limitation: The new branch-user, branch-servers, and guest-wifi zones were successfully created, but they did not appear as available options when assigning Security Zones to interfaces. Because of this simulator limitation, the interfaces could not be mapped to the new zones.

Part 2: Create 6 segmentation rules

13	deny-guest-to-servers	guest-wifi	any	any	branch-servers	any	any	application-default	deny	—
14	deny-guest-to-users	guest-wifi	any	any	branch-users	any	any	application-default	deny	—
15	allow-guest-web	guest-wifi	any	any	untrust	any	web-browsing-ssl	application-default	allow	○
16	allow-users-to-servers	branch-users	any	any	branch-servers	any	banking-app-printing	application-default	allow	○
17	deny-servers-to-users	branch-servers	any	any	branch-users	any	any	any	deny	—
18	allow-users-intrazone	branch-users	any	any	branch-users	any	any	any	allow	○

Part 3: Test Segmentation

Testing limitation: The simulator did not allow the newly created zones to be assigned to interfaces, so live traffic could not be generated between the Day 3 zones. The six required traffic flows were manually evaluated against the security policy using top-down, first-match rule processing.